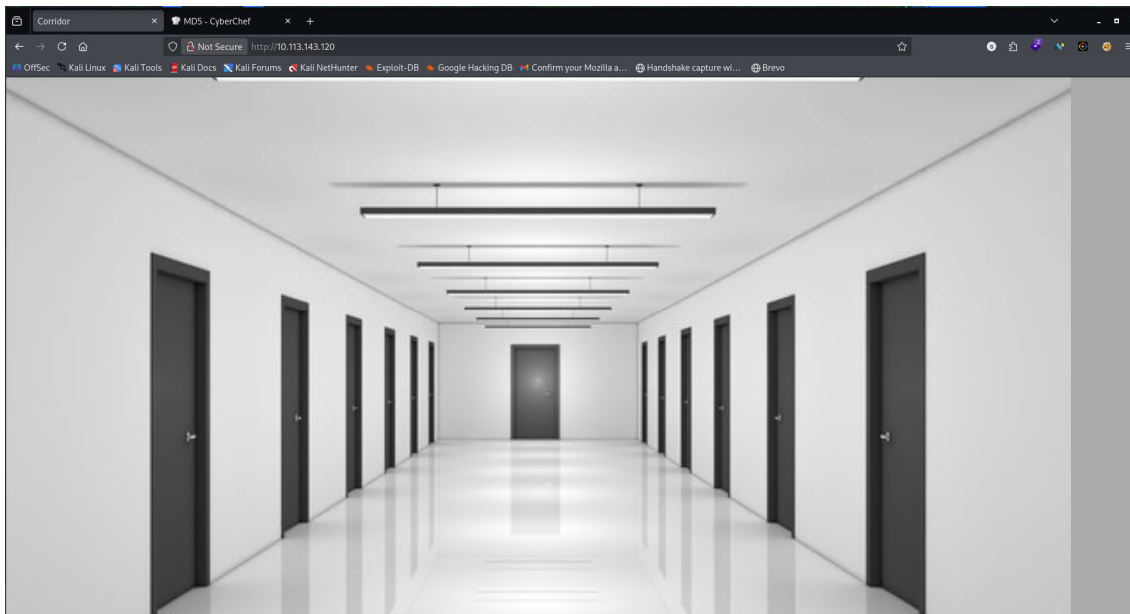


ESCAPE THE CORRIDOR WALKTHROUGH

“You have found yourself in a strange corridor. Can you find your way back to where you came?”

In this challenge, you will explore potential IDOR vulnerabilities. Examine the URL endpoints you access as you navigate the website and note the hexadecimal values you find (they look an awful lot like a hash, don't they?). This could help you uncover website locations you were not expecting to access”



This is all the information we got from the room. From this, we get a hint about **IDOR**, which refers to Insecure Direct Object Referencing. Basically, what this means here is that there is a URL with a parameter like `?id=1` or something like that, which we have to find, and we can change the value 1 to something else, and we will get information without being checked for any form of authorization concerning the page/info.

So after getting those urls we have to look out for some hexadecimal values, which potentially could be some useful hashes.

This was my understanding of the given information which gave me a starting point.

The first step had nothing to do with my interpretation of the given information, but I believe that scanning open ports and versions should be always the first step. That usually comes in handy later. So used nmap.

```
nmap -sV -O -oN scan.txt 10.113.143.120
```

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-27 15:21 +0200
```

```
Nmap scan report for 10.113.143.120
```

```
Host is up (1.2s latency).
```

```
Not shown: 999 closed tcp ports (reset)
```

```
PORT      STATE SERVICE VERSION
```

```
80/tcp open  http   Werkzeug httpd 2.0.3 (Python 3.10.2)
```

```
Device type: general purpose
```

```
Running: Linux 4.X|5.X
```

```
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
```

```
OS details: Linux 4.15 - 5.19
```

```
Network Distance: 3 hops
```

Only port 80 was open; I saved the results to scan.txt. I used searchsploit to search for this version of http service, but found nothing. I also searched on msf just to be sure, still nothing. So I moved on.

I ran directory enumeration with ffuf (I tried multiple wordlists).

```
urahara@Hogyoku:~$ ffuf -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt -u https://10.113.143.120/FUZZ -mc all -fs 42 -c -v
```



```
v2.1.0-dev
```

Method	GET
URL	https://10.113.143.120/FUZZ
Wordlist	FUZZ: /usr/share/wordlists/dirbuster/directory-list-1.0.txt
Follow redirects	false
Calibration	false
Timeout	10
Threads	40
Matcher	Response status: all
Filter	Response size: 42

```
:: Progress: [112017/141708] :: Job [1/1] :: 41 req/sec :: Duration: [0:56:59] :: Errors: 111977 :: $ ffuf -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt -u https://10.113.143.120/FUZZ -mc all -fs 42 -c -v
[ERR] NOPE
:: Progress: [141708/141708] :: Job [1/1] :: 40 req/sec :: Duration: [1:06:58] :: Errors: 141708 ::
```

In Firefox, it shows an image of a corridor with 13 doors, and when you click a door, you get a unique directory for that door. Something like;

Right

<http://10.113.143.120/c9f0f895fb98ab9159f51fd0297e236d>

<http://10.113.143.120/45c48cce2e2d7fbdea1afc51c7c6ad26>

<http://10.113.143.120/d3d9446802a44259755d38e6d163e820>

<http://10.113.143.120/6512bd43d9caa6e02c990b0a82652dca>

<http://10.113.143.120/c20ad4d76fe97759aa27a0c99bff6710>

<http://10.113.143.120/c51ce410c124a10e0db5e4b97fc2af39>

Centre

<http://10.113.143.120/8f14e45fceeaa167a5a36dedd4bea2543>

Left

<http://10.113.143.120/1679091c5a880faf6fb5e6087eb1b2dc>

<http://10.113.143.120/e4da3b7fbbce2345d7772b0674a318d5>

<http://10.113.143.120/a87ff679a2f3e71d9181a67b7542122c>

<http://10.113.143.120/eccbc87e4b5ce2fe28308fd9f2a7baf3>

<http://10.113.143.120/c81e728d9d4c2f636f067f89cc14862c>

<http://10.113.143.120/c4ca4238a0b923820dcc509a6f75849b>

I then ran directory enumeration on each of these.

```

urahara@HogYoku:~$ ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u http://10.113.143.120/45c48cce2e2d7fbdea1afc51c7c6ad26/FUZZ -mc all -fc 404 -c -
v2.1.0-dev

  Method      : GET
  URL         : http://10.113.143.120/45c48cce2e2d7fbdea1afc51c7c6ad26/FUZZ
  Wordlist    : /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
  Follow redirects : false
  Calibration : false
  Timeout     : 10
  Threads     : 40
  Matcher     : Response status: all
  Filter      : Response status: 404

Progress: [220560/220560] :: Job [1/1] :: 22 req/sec :: Duration: [1:26:17] :: Errors: 109 ::

urahara@HogYoku:~$

```

I still found nothing then I ran sqlmap with crawl flag to see if there is any parameters for any of these.

```
(urahara@Hogyoku)-[~]
$ sqlmap -u "http://10.113.143.120/45c48cce2e2d7fbdea1afc51c7c6ad26" --crawl=10 -v5 --batch
```



```
{1.10.6#stable}
```

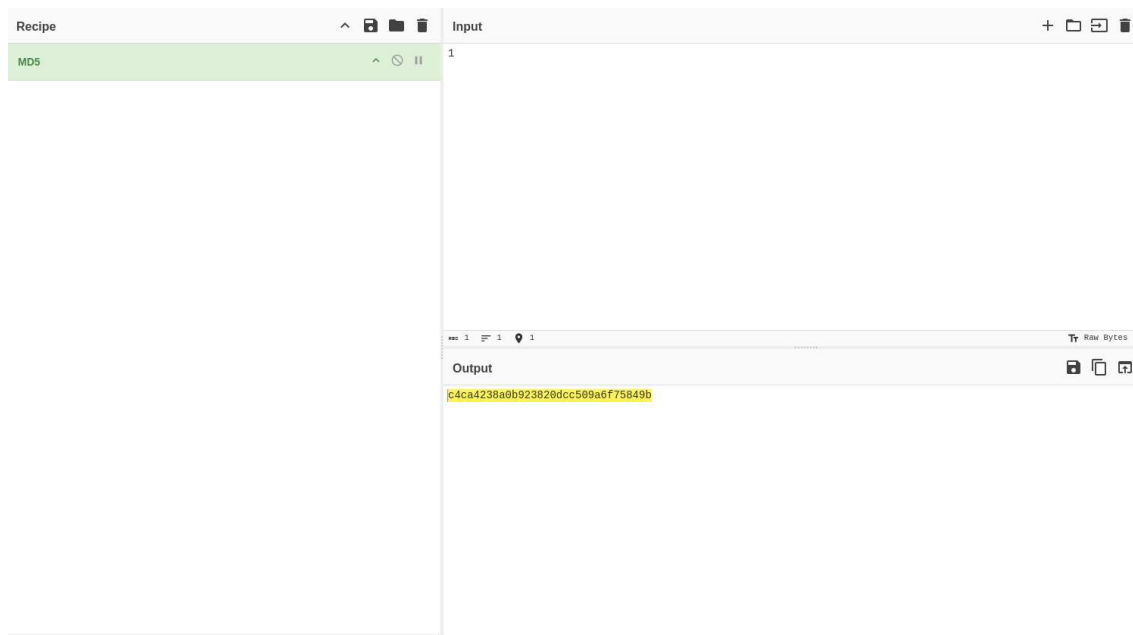
<https://sqlmap.org>

```
[20:24:32] [DEBUG] used the default behavior, running in batch mode
[20:24:32] [WARNING] running in a single-thread mode. This could take a while
[20:24:32] [WARNING] no usable links found (with GET parameters)

[*] ending @ 20:24:32 /2026-06-27/
```

After failing to find any parameters, I was convinced that were none. So back to the drawing board, I went back to analyze the statement again, and I realized that the hashes mentioned weren't necessarily in some typical parameter, infact, looking closer, the doors themselves were md5 hashes (the hint was in their length) and IDOR didn't necessarily mean that I have to change a typical value. I could even change the directory and maybe obtain the results I'm looking for.

Now the plan was to discover what the hashes meant. Since I could not decode the hashes I tried a couple of words on cyber chef like admin, flag and all that until I used 1 which matched to the 1st door hash.



Then I realized that all the doors are actually numbered by the hashes. Then “the way you came from made me think about what a typical developer would do, create a 0 door (I did this out of sheer guessing, there was no logical flow to my reasoning here). And that was the ultimate clue!

